CRITERION 06 / ASSESSMENT SUMMARY

Security documentation & reporting

DeRexi: Policy Pilot | Aurum Capital Bank | Evidence consolidated 11 October 2026

18	14	1	3
Test cases	Passing	Partial pass	Failed

Executive overview

This final assessment consolidates SSD1 Assignments 1–5 (development environment, secure coding, code analysis, OWASP ZAP scanning and best practices) with new local schema checks and read-only HTTP verification. Controls that passed include request validation, environment-file exclusion and user-name normalization. The most significant unresolved finding is a credential-enabled, wildcard CORS policy in the committed FastAPI code. Browser hardening headers are also absent.

Confirmed vulnerabilities

ID / severity	Finding	Evidence & impact
V-01 | HIGH	Wildcard CORS with credentials	Arbitrary origin accepted in live preflight; allow-credentials: true.
V-02 | MED	Missing Content Security Policy	CSP absent from GET /ui/ response.
V-03 | MED	Missing anti-clickjacking protection	Neither X-Frame-Options nor CSP frame-ancestors present.
V-04 | LOW–MED	External font integrity not enforced	OWASP ZAP flagged missing SRI; not retested on 11 Oct.
V-05 | LOW	No X-Content-Type-Options	Browser MIME-type hardening header absent.
V-06–09 | LOW	Error detail, CSS and contrast issues	Technical 422, invalid/duplicate CSS selectors; contrast previously flagged.

Assessment scope: Local-only development API. No database-writing tests were run; missing authentication/authorization and rate limiting are documented as structural MVP limitations rather than newly tested vulnerabilities.

VERIFIED TEST RECORD / PART ONE

Test execution & outcomes

Historical cases T-01–T-09 are transcribed from prior assignment reports; T-10–T-18 were checked on 11 October. PASS means the expected behavior was observed, not that the entire application is secure.

ID	Test / objective	Observed result	Status
T-01	Grounded AML policy answer	Referenced policy, related results, confidence	PASS · prior
T-02	Unsupported question	Declined to guess; routed clarification	PASS · prior
T-03	Malformed question “/”	Rejected with HTTP 422; exposed technical error	PARTIAL · prior
T-04	Stay Data Stay valid login	Correct credentials accepted	PASS · prior
T-05	Stay Data Stay invalid login	Generic failure message	PASS · prior
T-06	Stay Data Stay required fields	Blank values re-prompted	PASS · prior
T-07	Stay-length type and range	Invalid/nonpositive values rejected	PASS · prior
T-08	Allow-listed account choice	Unknown selection rejected	PASS · prior
T-09	Prevent duplicate account	Duplicate append prevented	PASS · prior
T-10	Whitespace-only policy question	ValidationError: string_too_short	PASS · new
T-11	Valid policy question schema	Accepted by request schema	PASS · new
T-12	One-character question	ValidationError: string_too_short	PASS · new
T-13	Missing user_id	ValidationError: field required	PASS · new
T-14	Incident severity allow-list	“urgent” rejected; “high” accepted	PASS · new
T-15	Policy status allow-list	“publish” rejected; “draft” accepted	PASS · new
T-16	Untrusted CORS preflight	Arbitrary origin allowed with credentials	FAIL · new
T-17	UI browser security headers	CSP, frame-control, nosniff absent	FAIL · new
T-18	Static CSS inspection	Invalid .ledger num; duplicate .gate	FAIL · new

Evidence note: 18 enumerated tests: 8 historical passes + 1 historical partial pass + 6 new passes + 3 new failures. The source evidence summary mistakenly labels 9 historical cases as passes; this corrected count follows the individual T-01–T-18 rows.

VULNERABILITY VALIDATION / PRIMARY EVIDENCE

How the findings were verified

Live preflight test

Request: OPTIONS /ask · Origin: http://evil.example · Access-Control-Request-Method: POST

Observed: HTTP 200 · access-control-allow-origin: http://evil.example · access-control-allow-credentials: true

The response explicitly permits this arbitrary origin while supporting credentialed requests. This directly contradicts earlier coursework reports stating CORS was restricted to approved origins. Canonical backend/main.py lines 59–65 still use allow_origins=["*"].

UI header verification

GET /ui/ returned HTTP 200. The checked response lacked Content-Security-Policy, X-Frame-Options and X-Content-Type-Options. OWASP ZAP had previously reported the browser-hardening issues. HSTS is not evaluated as a live deployment defect because the local test used HTTP loopback.

Risk & response priorities

Priority	Action	Current status
01 / HIGH	Restrict CORS to explicit permitted origins; verify preflight responses and credential use.	Not implemented
02 / MED	Implement and test CSP, anti-clickjacking and nosniff headers.	Not implemented
03 / MED	Add real authentication/authorization, user-based access checks and rate limiting before deployment.	Structural MVP gap
04 / LOW	Improve 422 error UX, external-resource integrity, CSS selectors and contrast.	Recommended / mixed verification

Evidence provenance

Prior sources: SSD1 Assignment 1 (environment and Git hygiene), Assignment 2 (Stay Data Stay input validation), Assignment 3 (SonarQube/runtime tests), Assignment 4 (OWASP ZAP), Assignment 5 (best practices). New evidence: 11 October schema assertions, local preflight response, UI response-header check and CSS inspection. No new screenshot, execution log or production-level penetration test was claimed.

REMEDIATION REGISTER / DOCUMENTATION CONTROL

Implemented vs. outstanding

Control or finding	Code / test reference	Verified disposition
Input validation	schemas.py; /ask; T-10–T-15	IMPLEMENTED · VERIFIED
.env Git exclusion	A#1 check-ignore; .gitignore	IMPLEMENTED
User.full_name normalization	models.py lines 66–68	IMPLEMENTED
Restrict CORS	main.py lines 59–65; T-16	NOT IMPLEMENTED
Content Security Policy	GET /ui/; T-17	RECOMMENDED · OPEN
Anti-clickjacking; nosniff	GET /ui/; T-17	RECOMMENDED · OPEN
Google Fonts SRI	OWASP ZAP A#4	OPEN · NOT RETESTED
Friendly invalid-input messages	Assignment 3, T-03	RECOMMENDED · OPEN
CSS selector corrections	style.css lines 121, 802, 843; T-18	RECOMMENDED · OPEN
Contrast remediation	Assignment 3 finding	NOT RE-MEASURED

Reporting accuracy & limitations

Some earlier SSD1 reports describe CORS as corrected; verification of the canonical committed code shows otherwise. This report treats code and live behavior as authoritative and explicitly preserves the discrepancy. Schema-level passes do not establish live database behavior. Stay Data Stay tests are historical, not re-executed. The evidence package notes no instructor-specific template was found; this report uses a standard security-documentation format.

Next verification checkpoints

After authorized code remediation: re-run the exact hostile-origin CORS preflight, verify browser security headers, re-check affected CSS, and document the remaining authentication and authorization architecture as Week 9 integration/security work. Do not claim remediation closed until code and runtime checks agree.

Source document: SSD1_Assignment_6_Evidence.md, 269 lines, prepared 11 October 2026. Project files and prior coursework evidence are referenced in that source; this report is an editorial consolidation rather than a substitute for the original evidence.